

Front vs. Back DEV y guía de endpoints

Usuarios, roles y permisos — qué quedó implementado en el front, qué hallazgos dejó y qué sigue abierto

Front	<code>feature/login-coctel-del-mar-integration</code> (commit base <code>ab89ce2</code> + los cambios de las v2.0 y v3.0, aún sin commit) — proyecto <code>reconciliation</code>
Back	rama <code>DEV</code> (commit <code>de23127</code>) — proyecto <code>coctel_midd</code> : <code>auth-service</code> , <code>gateway</code> , <code>sales-service</code> (nuevo) , <code>db-migration</code> (nuevo)
Guía del back	<code>Guia_Endpoints_Usuarios_Roles_Permisos</code> (14 pp.), respaldada sin cambios en <code>docs/implementaciones/Guia_Endpoints_Usuarios_Roles_Permisos_v1.0.pdf</code> .
Método	La guía se contrastó contra el código real de DEV (controladores, DTO, <code>SecurityConfig</code> , migraciones, <code>gateway</code>), no solo contra lo que dice el PDF. No se modificó nada del back ni de la guía.
Versión	3.0 — 08-Oct-2026 · Responsable portal: Irving Canul. Respaldos de las versiones anteriores en <code>docs/implementaciones/</code> (v1.0 y v2.0), sin cambios. Esta versión refleja que los 19 endpoints de la guía ya están conectados y deja los hallazgos nuevos.

1. Resumen

19

de los 19 endpoints de la guía ya están conectados al backend

8

se conectaron desde la v2.0 (sección 4): roles, permisos, PATCH roles, close-sessions, reset-password, DELETE y las 2 bitácoras

5

hallazgos abiertos para el equipo de back (sección 8)

3

endpoints de ventas (Sales Service, fuera de la guía) aún sin conectar

Resuelto desde la v2.0 (verificado: 136 pruebas de contrato contra el Gateway de DEV y recorridos en navegador)

- **Catálogos reales de roles y permisos** (`GET /roles` , `GET /permissions`): desaparecieron `ROLES` , `ROLE_LABEL` , `ROLE_OPTIONS` y `PERMISSIONS` ; el nuevo `AccessCatalogService` alimenta todos los selectores, el filtro de rol, el grid de permisos y las etiquetas.
- `PATCH /users/{id}/roles` y `POST /users/{id}/close-sessions` conectados; la sesión propia se renueva sola al cambiar los propios permisos.
- `POST /users/{id}/reset-password` y `DELETE /users/{id}` conectados; se reactivaron los botones "Eliminar" (lista y detalle).
- **Bitácora real** (`GET /audit-log` , `GET /users/{id}/audit-log`): filtros y paginación del lado del servidor; se eliminó la bitácora local y su mock.
- **Entorno (§5.3)**: proxy a las 6 rutas del Gateway (`proxy.conf.js` , puerto 8080), pila DEV reproducible con siembra de las 26 cuentas (`dev-env/`) y URL del Gateway configurable para Vercel (`API_URL`).

Hallazgos que siguen abiertos

- **Catálogo y matriz de permisos distintos a los del front**. DEV no define `view_catalogs` y su matriz por defecto es menor que la 7.16 del DED (§5.1–5.2); hoy se cumple solo con la siembra local. `capture_sales` existe pero el front no lo evalúa (Reprocesar usa una regla por rol).
- `GET /users` **pagina sin ORDER BY** : recorrer varias páginas puede repetir y omitir cuentas (probado: páginas de 10 sobre 27 cuentas → 21 distintas). El front lo compensa, pero conviene un `Sort` estable en el back.
- `PATCH /users/{id}/roles` **exige `manage_roles` en todo el endpoint** (también para cambiar solo permisos); la guía solo lo dice de los roles.

- `GET /roles /permissions` exigen `manage_users` o `manage_roles` : Contabilidad, Tesorería y Costos no pueden leer el nombre de su propio rol (el encabezado muestra el código legible).
- `PATCH /users/{id}/unlock` existe en DEV pero no aparece en la guía (allí el desbloqueo es `PATCH .../status {"status":"active"}`): el front depende de un endpoint sin documentar.

2. Matriz comparativa de endpoints

#	Método	Endpoint	Permiso en DEV	Estado en el front	Nota
1	POST	/auth/login	Público	Ajustado en v2.0	Muestra el mensaje del back (minutos de bloqueo restantes).
2	POST	/auth/refresh	Público	Implementado	Sin cambios de contrato.
3	POST	/auth/logout	Público	Implementado	Sin cambios.
4	GET	/auth/me	Sesión	Implementado	Sin cambios.
5	POST	/auth/change-password	Sesión	Ajustado en v2.0	Refresh posterior implementado; el 401 de negocio ya no cierra la sesión.
6	GET	/users	manage_users	Ajustado en v2.0	Autoriza por permiso; size=100 con paginación completa (listAllUsers).
7	GET	/users/{id}	manage_users	Ajustado en v2.0	failedLoginAttempts , activeSessions , lockedUntil mapeados.
8	POST	/users	manage_users	Ajustado en v2.0	Código INVALID_LOCATION en el catálogo de errores.
9	PATCH	/users/{id}	manage_users	Ajustado en v2.0	Envía subsidiariaIds / ubicacionIds ; multi-selects reactivados.
10	PATCH	/users/{id}/roles	manage_users + manage_roles	Implementado en v3.0	Envía solo lo que cambió; permisos por defecto desde GET /roles ; renueva la sesión propia. Exige manage_roles completo.
11	PATCH	/users/{id}/status	manage_users	Ajustado en v2.0	El estado local sigue la regla del back (active limpia el bloqueo).
12	POST	/users/{id}/verify-email	manage_users	Implementado	Sin cambios.
13	POST	/users/{id}/close-sessions	manage_users	Implementado en v3.0	Botón "Cerrar sesiones"; refleja activeSessions .
14	POST	/users/{id}/reset-password	manage_users	Implementado en v3.0	Temporal del back; cierra sesiones y marca cambio de contraseña. Se eliminó el generador local.
15	DELETE	/users/{id}	manage_users	Implementado en v3.0	Baja lógica con confirmación (lista y detalle); no sobre la propia cuenta. La lista poda las cuentas que el back ya no devuelve.
16	GET	/users/{id}/audit-log	view_audit_log	Implementado en v3.0	Pestaña Historial paginada en el servidor; deshabilitada sin view_audit_log .
17	GET	/audit-log	view_audit_log	Implementado en v3.0	Búsqueda, filtro de acción y paginación en el servidor; actor

nulo = "Sistema".

18	GET	/roles	manage_users o manage_roles	Implementado en v3.0	AccessCatalogService : selectores, filtro y etiquetas. Se eliminó ROLES .
19	GET	/permissions	manage_users o manage_roles	Implementado en v3.0	Grid de permisos agrupado por module . Se eliminó PERMISSIONS .
—	PATCH	/users/{id}/unlock	manage_users	Sin documentar	Existe en UserAdminController (l.143) pero no en la guía; el front lo usa vía unlockAccount() .

Conteo: 5 de /auth/* + 14 de usuarios/catálogos/bitácora = 19 en la guía; **los 19 están conectados** (11 hasta la v2.0 y 8 en la v3.0), más unlock , no documentado.

3. Cambios en los endpoints implementados hasta la v2.0 — estado en la v3.0

Endpoint	Qué cambió en DEV	Qué se hizo en el front	Estado
POST /auth/change-password	La guía advierte que el token vigente sigue marcado <code>mustChangePassword</code> ; hay que llamar a <code>/auth/refresh</code> inmediatamente después.	<code>AuthService.changePassword()</code> encadena el <code>refresh (rotateSessionAfterPasswordChange → requestTokenPair</code> , compartido con el <code>refresh</code> programado) y reemplaza la sesión. Si el <code>refresh</code> falla se invalida la sesión. <code>authTokenInterceptor</code> no cierra sesión ante 401 <code>INVALID_CREDENTIALS</code> . <code>ChangePassword</code> maneja también el 400 (nueva < 8). Verificado: el <code>refresh token</code> rota y se aterriza en el inicio.	Hecho
POST /auth/login	Bloqueo temporal de 2 h tras 5 intentos; desbloqueo automático. El 423 trae el mensaje con los minutos restantes.	<code>Login.onSubmit</code> muestra el error del back (<code>serverErrorText()</code>); <code>BLOCKED_MESSAGE</code> queda de respaldo. Verificado con cuenta bloqueada (el back local no manda minutos).	Hecho
GET /users	Autorización por permiso <code>manage_users</code> . <code>size</code> por defecto 20. Filtro <code>status</code> acepta <code>active inactive blocked</code> .	Se eliminó <code>forbiddenRoleMessage</code> (rol ADMIN/ALTAS); el 403 lo avisa el interceptor con texto de permiso. <code>size</code> se mantiene en 100 (<code>USERS_PAGE_SIZE</code>) y <code>AuthService.listAllUsers()</code> recorre las páginas (<code>expand + reduce</code>) para <code>syncFromBackend()</code> .	Hecho
GET /users/{id}	<code>UserDetailDto</code> gana <code>failedLoginAttempts</code> , <code>activeSessions</code> y <code>lockedUntil</code> .	Mapeados en <code>UserDetailDto</code> , <code>AppUser</code> (<code>lockedUntil</code> nuevo), mock, <code>buildUserFromDetail</code> , <code>mergeBackendDetail</code> , <code>createUser</code> , <code>setStatus</code> , <code>resetPassword</code> y el nuevo <code>unlockAccount()</code> . Seguridad y acceso muestra "Bloqueada hasta". Se leen con <code>?? 0 / ??</code> <code>null</code> por si el back es anterior.	Hecho
POST /users	Nuevo código 400 <code>INVALID_LOCATION</code> . El correo de un usuario dado de baja se puede reutilizar.	Código agregado a <code>ERROR_CODE_MESSAGES</code> (<code>auth-errors.ts</code>).	Hecho
PATCH /users/{id}	<code>UpdateUserRequest</code> acepta <code>subsidiariaIds</code> y <code>ubicacionIds</code> (reemplazo; vacía las quita; omitirla no toca). Un <code>null</code> explícito no borra un campo de texto.	Multi-selects de Organización reactivados en modo edición y enviados desde <code>updateUserProfile()</code> . El <code>AppUser</code> local toma las listas de la respuesta. Abierto: el front manda <code>null</code> al vaciar un campo de texto y eso no lo limpia en el back (aviso de UX). Con el back local no persiste (imagen de <code>feature/login</code>); DEV sí lo acepta.	Hecho · UX abierto
PATCH /users/{id}/status	<code>active</code> también desbloquea y borra el vencimiento; <code>blocked</code> es manual y no vence solo (<code>LOCKED</code>).	<code>setStatus</code> deja el registro local coherente: <code>active → 0 intentos</code> y <code>lockedUntil: null</code> ; <code>blocked → lockedUntil: null</code> .	Hecho
PATCH /users/{id}/unlock	No documentado en la guía, pero sigue en el código de DEV.	<code>unlockUser</code> devuelve el resumen y <code>unlockAccount()</code> actualiza el registro local (estado y contadores); el botón ya no mapea 403/404 a mano. La acción queda en la bitácora del back (<code>unlocked</code>). Abierto: migrar a <code>changeStatus(id, 'active')</code> o confirmar con back que <code>unlock</code> se mantiene.	Parcial

Todos los de <code>/users/**</code>	Seguridad por <code>hasAuthority</code> : el JWT lleva roles y permisos. Los cambios de permisos se ven en el siguiente refresh (máx. 15 min).	Textos de 403 por permiso, no por rol (interceptor). v3.0 : al cambiar los roles/permisos de la propia cuenta, <code>AuthService.renewSession()</code> hace <code>POST /auth/refresh</code> + <code>GET /auth/me</code> y los refleja al instante.	Hecho en v3.0
Códigos de error	Nuevos: <code>INVALID_PERMISSION</code> , <code>INVALID_LOCATION</code> , <code>CANNOT_DELETE_SELF</code> (409).	Los 16 códigos de la guía en <code>ERROR_CODE_MESSAGES</code> con gestión en <code>httpErrorAlertInterceptor</code> : <code>PASSWORD_CHANGE_REQUIRED</code> → aviso + <code>markPasswordChangeRequired()</code> + <code>/cambiar-password</code> ; 403 sin código → "sin permiso"; 5xx → error del servidor; códigos con UI propia sin toast duplicado. <code>SESSION_IDLE_TIMEOUT</code> cierra la sesión con motivo <code>idle_timeout</code> también fuera del refresh.	Hecho

Detalle técnico y verificación en los addendums de `design-system/conciliation/MASTER.md` .

4. Endpoints conectados en la v3.0

Cada uno con lo que se hizo y lo que se encontró al probarlo contra el Gateway de DEV (`dev-env/pruebas-endpoints.mjs`).

GET /roles GET /permissions Catálogos · Implementado		
Hecho	Nuevo <code>AccessCatalogService</code> (<code>user-management/data</code>): un <code>effect</code> pide ambos catálogos al iniciar sesión y los limpia al cerrarla; expone <code>roleOptions</code> , <code>permissionGroups</code> (por <code>module</code>) , <code>roleLabel()</code> , <code>permissionLabel()</code> y <code>defaultPermissionsForRoles()</code> . Se eliminaron <code>ROLES</code> , <code>ROLE_LABEL</code> , <code>ROLE_OPTIONS</code> , <code>PERMISSIONS</code> y <code>defaultPermissionsForRoles</code> del modelo; <code>RoleDef</code> pierde <code>description</code> (el back no la manda) y <code>PermissionKey</code> suma <code>capture_sales</code> . Consumidores: selector y filtro de rol de la lista, selector de rol del alta y de "Seguridad y acceso", grid de permisos, encabezado, perfil.	
Hallazgo	Exigen <code>manage_users</code> o <code>manage_roles</code> (403 sin código si faltan). Para Contabilidad, Tesorería y Costos no se piden y el rol se muestra con una versión legible del código ("Tesoreria", "Contabilidad"). <code>AccessControlService</code> ya no recalcula permisos desde el rol: <code>AuthUser.permissions</code> es la única fuente.	
PATCH /users/{id}/roles Guardar roles y permisos · Implementado		
Hecho	<code>changeRoles()</code> pasó de local a <code>Observable</code> : manda solo <code>roleIds</code> y/o <code>permissions</code> que cambiaron (omitido = no tocar), reconcilia con el <code>UserSummaryDto</code> de la respuesta y, si la persona editada es la de la sesión, renueva la sesión (<code>renewSession</code>). La regla "cambio de rol → permisos por defecto" la aplica el front con <code>GET /roles</code> y envía el resultado final. Un rechazo restaura el selector.	
Hallazgo	El endpoint entero exige <code>manage_roles</code> (403 <code>ROLE_ASSIGNMENT_FORBIDDEN</code>), también para un cambio solo de permisos. Por eso, sin ese permiso, la sección "Roles y permisos" del detalle y el selector de rol de la lista quedan de solo lectura. En el alta, la UI no bloquea el selector: el back responde 403 si falta.	
POST /users/{id}/close-sessions POST /users/{id}/reset-password Sesiones y contraseña · Implementado		
Hecho	<code>closeSessions()</code> y <code>resetPassword()</code> son <code>Observable</code> y usan la respuesta (<code>activeSessions</code> ; <code>temporaryPassword</code>). El reset marca <code>mustChangePassword</code> , deja las sesiones en 0 y muestra la temporal en un toast y en Organización; se quitó el "desbloqueo" local que hacía el reset (la guía no lo dice). Se eliminó <code>password.util.ts</code> (generador local) y el login simulado local (<code>recordFailedLogin</code> / <code>clearFailedLogins</code>).	
Probado	La temporal sigue la regla NOMBRE + PRIMER APELLIDO + año (mayúsculas, sin acentos); la contraseña anterior deja de servir; los refresh tokens de las sesiones cerradas responden 401; la persona puede volver a entrar.	

DELETE /users/{id}		Baja lógica · Implementado
Hecho	Se reactivaron "Eliminar" (fila de la lista) y "Eliminar usuario" (encabezado del detalle) con confirmación; ambos se deshabilitan en la propia cuenta (el back responde 409 CANNOT_DELETE_SELF). syncFromBackend() ahora saca de la lista local las cuentas con backendUserId que GET /users ya no devuelve (baja hecha en otra sesión o DB re-sembrada).	
Probado	La cuenta desaparece del listado y del detalle (404), no puede iniciar sesión, su historial se conserva (acción deleted) y su correo se puede volver a dar de alta.	

GET /audit-log · GET /users/{id}/audit-log		Bitácora · Implementado
Hecho	AuditLogService mapea la bitácora real; "Historial y auditoría de usuarios" busca (detalle, actor, persona), filtra por acción y pagina en el servidor (15 por página); la pestaña Historial del detalle pagina de 10 en 10, se recarga tras cada acción y se deshabilita sin view_audit_log . Se eliminaron MOCK_AUDIT_LOG , la bitácora local y todas las llamadas a appendAudit() (el back ya registra cada acción). AuditAction usa el vocabulario del back (created , updated , organization_updated , status_changed , locked , unlocked , role_changed , permissions_changed , password_reset , email_verified , sessions_closed , deleted); un código nuevo se muestra tal cual.	
Probado	Orden de la más reciente a la más antigua; actor: null en el bloqueo automático (se muestra "Sistema"); filtros userId , action y search ; paginación sin repetir filas; 404 si la persona nunca existió; 403 sin view_audit_log (permiso independiente de manage_users).	

4.1 Verificación

dev-env/pruebas-endpoints.mjs (node dev-env/pruebas-endpoints.mjs) ejecuta **136 verificaciones de contrato** contra el Gateway de DEV: login, refresh y reuso, cambio de contraseña con refresh, GET /users y su paginación, detalle con los 3 campos nuevos, alta, PATCH , estado, desbloqueo, verificación de correo, roles y permisos con y sin manage_roles , cierre de sesiones, reset, bitácora (filtros, orden, paginación) y baja lógica, más los 400/401/403/404/409/423 de cada uno. Las cuentas de prueba se dan de baja al terminar. Además se recorrieron en navegador los flujos de cada pantalla.

5. Cambios transversales que condicionan la implementación

5.1 Catálogo de permisos: DEV vs. front

Permiso	DEV (guía + migraciones)	Front hoy	Consecuencia
capture_sales	Sí (migración V2, solo ADMIN)	En el tipo <code>PermissionKey</code> y en el grid (viene de <code>GET /permissions</code>); no se evalúa	Gatearía <code>POST /sales/capture</code> (§7). "Reprocesar" sigue usando una regla por rol (ADMIN, CONTABILIDAD) y es una simulación.
view_catalogs	No existe	Sí (pantalla <code>/catalogos</code> , menú, guard)	Contra un DEV limpio, <code>/catalogos</code> queda inaccesible para todos. El back local lo siembra (<code>dev-env/seed-demo-users.sql</code>); falta que el equipo de back lo siembre o que la pantalla cambie de permiso.
Los otros 8	Coinciden (<code>view_dashboard</code> , <code>view_reconciliation</code> , <code>manage_differences</code> , <code>import_settlements</code> , <code>export_reports</code> , <code>manage_users</code> , <code>manage_roles</code> , <code>view_audit_log</code>)	—	—

5.2 Permisos por defecto de cada rol

Rol	DEV puro (migración V1)	Backend local sembrado (<code>GET /roles</code> hoy)	Diferencia
ADMIN	Los 9 (incluye <code>capture_sales</code>)	Los 10 (suma <code>view_catalogs</code>)	+1 (<code>view_catalogs</code>).
ALTAS	<code>manage_users</code> , <code>manage_roles</code> , <code>view_audit_log</code>	Igual	—
CONTABILIDAD	<code>view_dashboard</code>	<code>view_dashboard</code> , <code>export_reports</code> , <code>view_catalogs</code>	+2 (matriz 7.16).
TESORERIA	<code>view_reconciliation</code> , <code>manage_differences</code> , <code>import_settlements</code> , <code>export_reports</code>	Anteriores + <code>view_dashboard</code> , <code>view_catalogs</code>	+2: contra DEV puro Tesorería no ve ventas.
COSTOS	ninguno	<code>view_dashboard</code> , <code>export_reports</code> , <code>view_catalogs</code>	Contra DEV puro, Costos no entra a ninguna pantalla.

El front ya no lleva su propia matriz (se eliminó `ROLES`): lo que ve cada rol sale de `GET /roles` y de `AuthUser.permissions` . La "matriz 7.16 completa" del DED **solo se cumple con la siembra local**; con un DEV limpio habrá que (a) pedir al back que ajuste los defaults, o (b) aceptar la matriz de DEV y reflejarlo en la comparativa. La matriz funcional completa (cada funcionalidad del front × cada rol) está en `docs/Matriz_Roles_Permisos_Frontend.xlsx` .

5.3 Entorno y configuración del front — resuelto en la v3.0

Tema	Estado y cómo quedó
Gateway y proxy	Hecho. <code>proxy.conf.json</code> → <code>proxy.conf.js</code> : reenvía <code>/auth</code> , <code>/users</code> , <code>/roles</code> , <code>/permissions</code> , <code>/audit-log</code> y <code>/sales</code> a <code>http://localhost:8080</code> (<code>GATEWAY_URL</code> lo cambia si el puerto está ocupado). Ninguna ruta choca con las del portal.
Base de datos	Hecho. <code>dev-env/levantar-backend.ps1</code> levanta la pila de DEV (db-migration → auth, sales, gateway) con el <code>docker-compose.yml</code> del back sin modificarlo (proyecto <code>coctel_dev</code> , volumen nuevo) y siembra con <code>dev-env/seed-demo-users.sql</code> las 26 cuentas demo (ids 2–27, mismos

hashes/estados/roles/permisos) y el catálogo de organización. La pila anterior se renombró `*-legacy` con su volumen intacto.

CORS y Vercel	Hecho en el front. <code>environment.apiUrl</code> sale de <code>src/environments/api-url.ts</code> ('' en desarrollo); en Vercel, <code>API_URL=https://<gateway></code> y Build Command <code>node scripts/set-api-url.mjs && npm build</code> . Pendiente del lado del back: el dominio del portal debe estar en <code>CORS_ALLOWED_ORIGINS</code> del Gateway.
Renovación de tokens	Hecho. Un solo timer; <code>changePassword()</code> y <code>renewSession()</code> lo cancelan antes de pedir el par nuevo (dos <code>/auth/refresh</code> con el mismo token se interpretan como robo). Ambos usan <code>requestTokenPair</code> .
Paginación	Hecho, con una salvedad. <code>listAllUsers()</code> recorre todas las páginas con <code>size=100</code> , pero <code>GET /users</code> pagina sin <code>ORDER BY (+ DISTINCT)</code> : entre páginas puede repetir y omitir cuentas. El front junta por <code>id</code> y, si faltan respecto de <code>totalElements</code> , pide una sola página de ese tamaño. Con ≤ 100 cuentas no se nota. La bitácora sí pagina en el servidor (tiene <code>ORDER BY createdAt DESC</code>).
Gateway y contraseña pendiente	Hecho. El Gateway rechaza con un 403 sin código (formato Spring) el token con <code>mustChangePassword</code> : nunca llega <code>PASSWORD_CHANGE_REQUIRED</code> por ahí. El interceptor lo trata como tal cuando la sesión está marcada como pendiente; si no, muestra "sin permiso".

6. Estado del orden de implementación

#	Entregable	Estado	Pendiente
1	Alinear entorno: pila DEV, siembra, proxy/puertos	Hecho (v3.0)	—
2	Decisión de permisos: <code>view_catalogs</code> , <code>capture_sales</code> y matriz por defecto (§5.1–5.2)	Abierto	Equipo back / DED
3	Ajustes a lo ya implementado (§3)	Hecho (v2.0–v3.0)	<code>unlock→status</code> (depende de la pregunta al back) y no mandar <code>null</code> al vaciar campos de texto.
4	<code>GET /roles</code> + <code>GET /permissions</code> y retiro de las constantes	Hecho (v3.0)	—
5	<code>PATCH /users/{id}/roles</code>	Hecho (v3.0)	—
6	<code>reset-password</code> y <code>close-sessions</code>	Hecho (v3.0)	—
7	Bitácora (<code>/audit-log</code> , <code>/users/{id}/audit-log</code>)	Hecho (v3.0)	—
8	<code>DELETE /users/{id}</code>	Hecho (v3.0)	—
9	Sales Service (§7)	Abierto	Alto esfuerzo; depende de 2 y de las respuestas del back.

7. Sales Service (nuevo en DEV, fuera de la guía)

DEV agrega `sales-service` detrás del gateway (`/sales/**`). Hoy "Resumen de venta", "Conciliación", "Gestión de diferencias" y "Catálogos" usan datos de ejemplo en memoria. Se documenta porque es lo siguiente a conectar y comparte el modelo de permisos.

Método	Endpoint	Permiso	Qué hace / respuesta
POST	<code>/sales/capture</code>	<code>capture_sales</code>	Captura manual (síncrona, idempotente) de <code>{ ubicacionId, date }</code> desde Facturiza. 200 OK · 207 incompleta · 502 Facturiza no respondió · 409 ya se está capturando · 404 ubicación inexistente. Respuesta con conteos (declarados, capturados, insertados, omitidos, fallidos), monto y páginas.
GET	<code>/sales/captures</code>	<code>view_dashboard</code>	Historial de corridas de <code>ubicacionId</code> + <code>date</code> (manuales y automáticas), la más reciente primero.
GET	<code>/sales/summary</code>	<code>view_dashboard</code>	Resumen del día por ubicación: documentos (conteo, subtotal, impuestos, cargos, total), pagos por medio, impuestos por tributo y extras

(descuentos/propinas).

Alcance real para el portal. No hay un listado ni detalle de ventas individuales: `/sales/summary` es un **agregado por día y ubicación**. La tabla de "Resumen de venta", el drawer de detalle fiscal y la exportación CSV **no se pueden alimentar** con estos endpoints (siguen siendo "Faltante" en la comparativa DED, 7.4). Sí encajan: el botón **Reprocesar** (→ `POST /sales/capture`, con rango/ubicación reales; ya tiene el permiso `capture_sales`), un resumen diario y el historial de capturas. `ubicacionId` es el id numérico de `AuthUser.ubicaciones`, lo que elimina el puente por nombre (`LABEL_TO_STORE`).

8. Preguntas abiertas para el equipo de back

- ¿ `PATCH /users/{id}/unlock` se conserva o desaparece a favor de `status: active` ? (la guía no lo menciona).
- ¿Se sembrará `view_catalogs`, o la pantalla de catálogos cambia de permiso?
- ¿Se ajustan los defaults de Contabilidad/Tesorería/Costos (§5.2) a lo que decidió el DED 7.16?
- ¿Se puede agregar un `Sort` estable (p. ej. por `id`) a `GET /users` ? Hoy la paginación entre páginas no es confiable (§5.3).
- ¿ `GET /roles` y `GET /permissions` pueden abrirse a cualquier sesión (o `GET /auth/me` traer el nombre de los roles)? Hoy Contabilidad, Tesorería y Costos no pueden mostrar el nombre de su rol.
- ¿ `PATCH /users/{id}/roles` debe exigir `manage_roles` también para cambios solo de permisos? Es lo que hace hoy; la guía solo lo menciona para roles.
- ¿Habrá endpoint para listar/detallar ventas individuales (7.4) o solo el agregado diario?
- Para Vercel: ¿cuál será el origen del Gateway y se agregará el dominio del portal a `CORS_ALLOWED_ORIGINS` ?

9. Historial de versiones

Versión	Fecha	Cambios
1.0	06-Oct-2026	Primer análisis: front <code>ab89ce2</code> vs. back DEV <code>de23127</code> y guía <code>Guia_Endpoints_Usuarios_Roles_Permisos</code> . Respaldado en <code>docs/implementaciones/analisis-front-vs-back-dev_v1.0.pdf</code> .
2.0	06-Oct-2026	Se marca lo resuelto en el front: ajustes a login, change-password, <code>GET /users</code> , <code>GET /users/{id}</code> , <code>PATCH /users/{id}</code> y catálogo completo de errores (§1–§3); se actualizan §4–§6 y §8 con lo que sigue abierto. Respaldada en <code>docs/implementaciones/analisis-front-vs-back-dev_v2.0.pdf</code> .
3.0	08-Oct-2026	Los 19 endpoints de la guía quedan conectados: <code>GET /roles</code> , <code>GET /permissions</code> , <code>PATCH /users/{id}/roles</code> , <code>POST .../close-sessions</code> , <code>POST .../reset-password</code> , <code>DELETE /users/{id}</code> y las dos bitácoras (§4); entorno y configuración del front resueltos (§5.3); hallazgos nuevos (paginación sin orden, <code>manage_roles</code> en todo el PATCH, catálogos de roles solo con <code>manage_users / manage_roles</code>) y preguntas al back actualizadas (§1, §8). Se retiran las constantes de roles/permisos y la bitácora local.